

COMPSCI5079 (M)

Cryptography & Secure Development

Dr. Nguyen Truong

Lecturer (Assistant Professor), SoCS, University of Glasgow

Email: Nguyen.Truong@Glasgow.ac.uk

Office: SAWB 221C, Sir Alwyn Williams Building, 18 Lilybank Gardens



Lecture 4:

Message Digests, Random Numbers and Secret Sharing





Outline

1. Message Digest

- Message Digest Concept
- Design a Hash Function

2. Random Numbers

- Real Random numbers
- Pseudo-random numbers
- Cryptographically Secure Pseudo-random numbers

3. Secret Sharing (Multiple key cryptography)

- Secret Splitting
- Secret Sharing



Random Numbers



Random Numbers Generator

1. Pseudo-random Numbers

- A pseudo-random number sequence looks like a real random number sequence but is repeatable.

2. Cryptographically Pseudo-random Numbers

- A cryptographically secure pseudo-random number sequence cannot be predicted from some of the numbers in the sequence.

3. Real Random Numbers

- A real random number sequence cannot be repeated if the generator is run again.



Pseudo-Random Sequences

- Pseudo-random number sequences are sequences that are completely predictable from the starting value.
- Their distribution looks random
 - The frequency distribution of values, pairs of values etc., is the same as a random sequence.
- They are useful for simulation.
- They can sometimes be useful for encryption, but care must be taken.



Linear Congruential Generators (LCG)

- These use the following formula to generate a series of numbers:

$$X_n = (aX_{n-1} + b) \bmod m$$

- The first value, X_0 , is the seed of the sequence.
- These operators are fast and produce good properties, provided the values of a , b and m are chosen well.
- Unfortunately, they are not cryptographically secure, and so cannot be used for encryption.
- There are many other applications in cryptography for which this type of sequence is good enough.



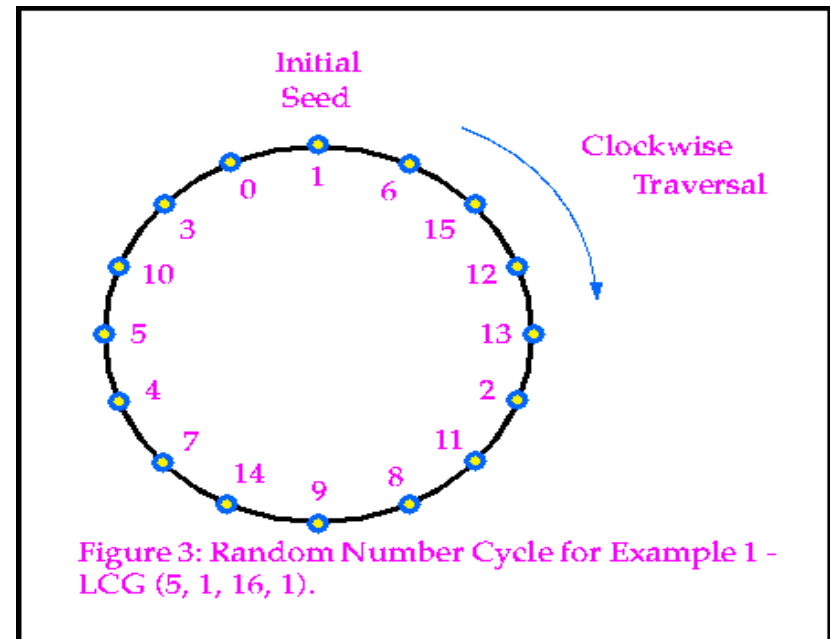
LCG Example

$LCG(a,b,m,X_0)$

- Example: $LCG(5, 1, 16, 1)$
 - $a=5$, $b=1$, $m=16$, and $X_0=1$
- The sequence of pseudo-random integers generated by this algorithm is:

1, 6, 15, 12, 13, 2, 11, 8, 9, 14, 7, 4, 5, 10, 3, 0,

1, 6, 15, 12, 13, 2, 11, 8, 9, 14, ..





LCG Example

We observe that:

- The period P (the number of integers before the sequence repeats) is 16 - exactly equal to the modulus, m . Thus, for $m=16$, this sequence is of a long period (the longest possible), and uniform (it completely fills the space of integers from 0-15).
- Sequence exhibits throughout its period the pattern of alternating odd and even integers.
- It is readily apparent that the sequence is serially correlated.
 - Due to this lack of randomness, the values should not be used as random digits.
 - The real numbers generated from the integer sequence are generally sufficiently random in the higher order (most significant) bits to be used in many application codes.



LCG Example

Lehmer/Park and Miller

- An instance of LCG with particular parameters
- An established standard known as MINSTD
 - $m = 2147483647$ ($2^{31} - 1$ a Mersenne prime*)
 - $a = 16807$ (7^5)
 - $b = 0$
- If X_i is very small, then X_{i+1} will also be very small. This is a weakness.

*https://en.wikipedia.org/wiki/Mersenne_prime



Cryptographically Secure Pseudo-Random Sequences

- The sequence looks random and is also unpredictable.
 - Knowledge of all the preceding numbers in the sequence does not make it easier to predict the next number in the sequence.
- It is not possible to calculate the seed to generate a given sequence.
 - So, we cannot find the seed which will generate a short sequence of random numbers provided in advance.
- Elliptic curves (see the next session) are the most commonly used cryptographically secure random number generators.



Running Key Ciphers with Pseudo-Random Numbers

- If the sequence is cryptographically secure, then it can be used as a running key cipher.
 - Let M_i be a sequence of message blocks and R_i be a sequence of Pseudo-Random numbers.
 - Then $C_i = M_i \oplus R_i$ is the ciphertext.
 - The single key to the algorithm is the initial value (seed) of the sequence.
- All pseudo-random sequences are periodic, but the period is usually much longer than the message that is being encrypted.



Real Random Sequences

- Real random sequences have all the properties of pseudo-random sequences, and also an additional property.
 - They cannot be reliably reproduced.
 - If you run the generator twice with the same input, the resulting sequences will be different.



Real Random Sequences

- These sequences can be used as a one-time pad. All the values must be stored.
- In 1955 the RAND Corporation published a book containing 1,000,000 random digits.
 - They were produced before the computer era, and so do not have any computer-induced bias.
 - Thus, they are still used now.



Generating Real Random Sequences

➤ Computer Clock:

- The most significant bits will stay the same for long periods of time and will be easy to predict.
- The least significant few bits from the system time will be reasonably difficult to predict.
- The least significant bit may have some periodicity based on the natural machine clock cycle.
- Taking the middle chunk of bits from a very accurate clock is best.



Generating Real Random Sequences

- Keyboard Latency
 - Measure the time between successive keystrokes, which is quite random.
 - This is OK for generating short random sequences.
 - Requires a person to press the keys.
- Using Random Noise
 - Measure the time interval between random events such as atmospheric noise being above a certain threshold.



Problems with PRNG: Netscape Case-study

Netscape's Pseudo-Random Generator

- In 1996 two Computing students discovered a flaw in Netscape's PRNG that enabled them to easily break SSL.
 - Secure Sockets Layer, now replaced by Transport Layer Security.
- At that time, the US government viewed crypto products as munitions and prevented their exports to non-Americans
 - The USA SSL key length was 128 bits, which would take a long time to break with a brute force attack.
 - Export versions had a key length of 40 bits, which would require $2^{40} \approx 10^{12}$ attempts.
 - Just about anyone could break the export version with a Brute-force attack.

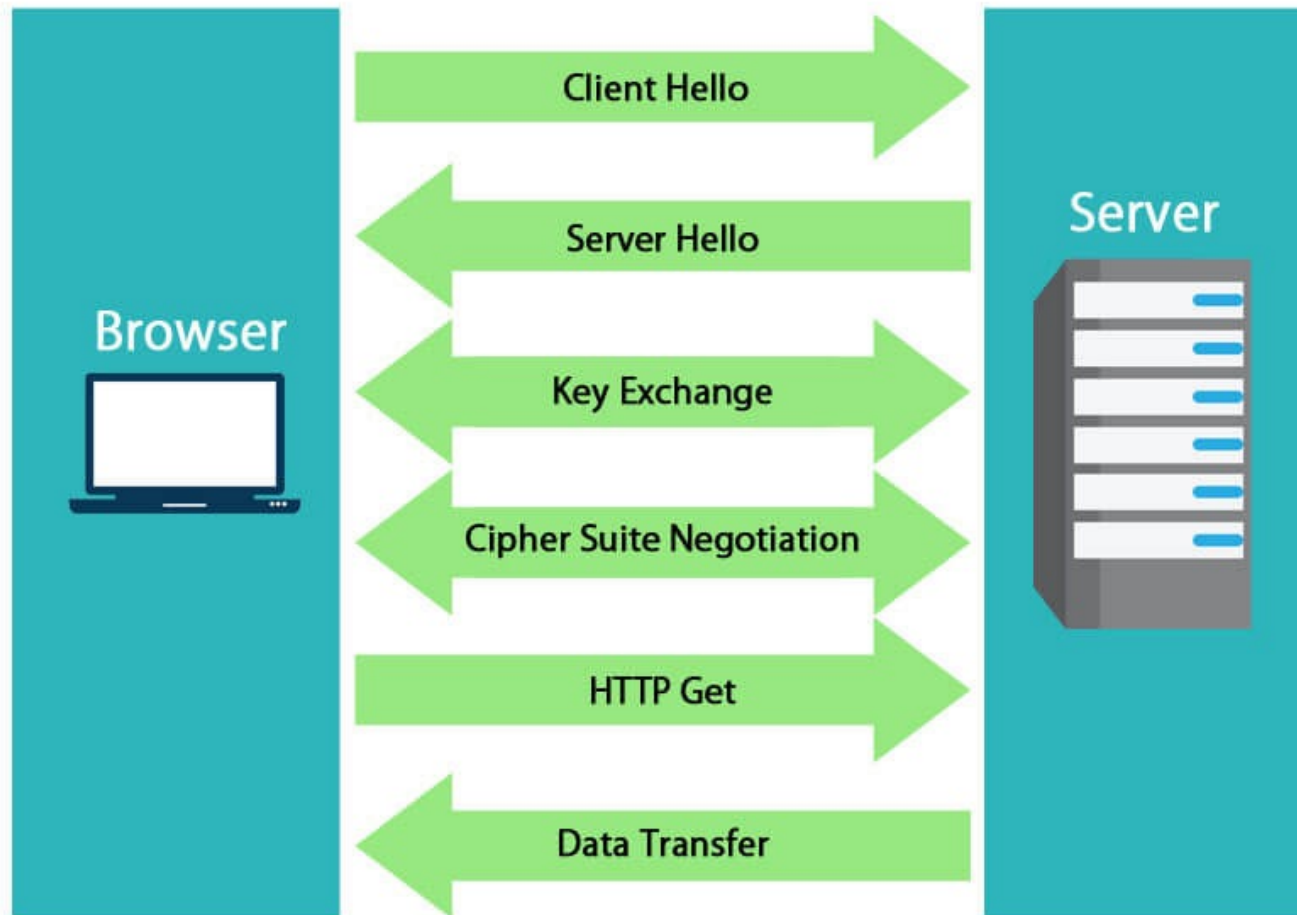


Secure Socket Layer

- A Secure Socket Layer (SSL): security protocol developed by Netscape in 1995
- SSL encrypts data that is transmitted across the web.
- SSL initiates an authentication process called a handshake between two communicating devices
 - The SSL (or TLS) client sends the random byte string that enables both the client and the server to compute the secret key to be used for encrypting subsequent message data.
- SSL also digitally signs data in order to provide data integrity, verifying that the data is not tampered with before reaching its intended recipient



SSL Protocol





Netscape's PRNG

- A random number generator was called 4 times to generate the key.
- The weakness was in the way the initial seed was chosen.
 - It was based on the process number, the parent process number and the time in milliseconds.
- It was fairly easy for an attacker to find out the process numbers and the time to the nearest second.
- Communications were initiated by one party sending a random number and the other replying with the encrypted version.
 - Thus, a known plaintext attack was possible.
- Just 10^6 attempts were needed to break both the USA and export versions of Netscape SSL.
 - It took 25 seconds on a standard PC at the time.



- $$y^2 = x^3 + ax + b$$

- In 2007 NIST issued a new random number standard with 4 algorithms. The recommended and default algorithm was `Dual_EC_DRBG`.
- It was recommended by the NSA.
- There were already questions about the algorithm.



Crypto 2007: Aug 2007

- Dan Shumow and Niels Ferguson from Microsoft demonstrated that the algorithm had some secret parameters used to derive the public parameters.
- These secret parameters could be used to recover all the internal workings of the PRNG from 32 bytes of output.
- Prominent figures in the crypto community at the time, such as Bruce Schneier, recommended that `Dual_EC_DRBG` should not be used.



OpenSSL

- This is an open-source library of crypto implementations.
- The OpenSSL project was founded in 1998 to provide a free set of encryption tools for the code used on the Internet.
- The user could choose between several different pseudo-random number generators.
 - `Dual_EC_DRBG` was one of them, although not the default.
- A coding bug discovered in December 2013 meant that it was impossible to choose `Dual_EC_DRBG` as the random number generator.
- There were no bug reports, and so no one had tried.



NIST and RSA

- The RSA organisation used `Dual_EC_DRBG` in its product `Bsafe` as the default, on recommendation from the NSA, starting in 2004.
- In September 2013 NIST strongly recommended that `Dual_EC_DRBG` no longer be used.
- RSA then also recommended that it not be used.



Summary

- Random Numbers Generators
 - Real random numbers based on keyboard latency time or physical fluctuations
 - Pseudo-random numbers are predictable but have random statistics.
 - Cryptographically secure pseudo-random numbers - knowledge of part of the sequence cannot generate the rest.



Quizzes

1. Describe the differences between real random numbers, pseudo-random numbers and cryptographically secure pseudo-random number sequences.
2. Give one algorithm for producing each of the above types of random numbers (three algorithms in total).